



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-49869 Kestra OSS OS Command Injection Daily Priority Update 2026-09-07

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-09-07
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-49869 Kestra OSS OS Command Injection Daily Priority Update 2026-09-07 - CVE / Vulnerability Threat Intelligence Report

Published: 2026-09-07 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Daily Freshness Note
2. Executive Summary
3. Intelligence Requirements
4. Source Review & Confidence
5. Vulnerability / Threat Details
6. Exposure and Attack Scenarios
7. Detection Engineering
 - 7.1. Detection Summary
 - 7.2. Sigma / Detection Content
8. Threat Hunting
 - 8.1. Hunt Hypothesis
9. MITRE ATT&CK Mapping
10. Recommended Actions
11. References

CVE-2026-49869 Kestra OSS OS Command Injection Daily Priority Update 2026-09-07

1. Daily Freshness Note

This 2026-09-07 daily report was selected from current public reporting and recent authoritative source updates. Automated source review found the topic still within the current 7-day defender-priority window; no unsupported same-day disclosure claims are made. Where public details remain incomplete, the report labels uncertainty and prioritizes defensible exposure review, detection engineering, and threat hunting over unsupported attribution or invented IOCs.

2. Executive Summary

CISA added CVE-2026-49869 to KEV on 2026-09-02. Public vulnerability descriptions state Kestra OSS before fixed releases allowed unauthenticated attackers to reach workflow functionality and execute arbitrary commands in an orchestration platform context.

Primary exposure: Kestra OSS workflow-orchestration deployments, especially unauthenticated or weakly segmented instances exposed to internal users, CI/CD paths, or the internet.

3. Intelligence Requirements

Question	Current Answer	Confidence
What happened?	Public sources indicate the topic is active or operationally important in the current 24-72 hour defender window.	Medium-High
Who should care?	Security operations, vulnerability management, identity, platform, and sector-risk owners with relevant exposure.	High
What should be done today?	Validate exposure, apply mitigations, run hunts, and prioritize incident-response readiness for affected assets.	High

4. Source Review & Confidence

Source	URL	Contribution
CISA KEV alert	https://www.cisa.gov/news-events/alerts/2026/09/02/cisa-adds-seven-known-exploited-vulnerabilities-catalog	Authoritative active-exploitation prioritization.
NVD	https://nvd.nist.gov/vuln/detail/CVE-2026-49869	Vulnerability description and affected Kestra OSS versions before 1.0.45 and 1.3.21.
SecurityArsenal	https://securityarsenal.com/blog/cve-2026-49869-kestra-oss-unauthenticated-os-command-injection-actively-exploited-detection-hunting-and-remediation-guide	Current defender-focused remediation and hunt context.
CVEfeed	https://cvefeed.io/vuln/detail/CVE-2026-49869	Supporting CVE summary and references.

Source depth is sufficient for a defensive Lost Boys Cyber report. No claims, exploit status, actor names, or IOCs were added unless supported by the cited source set.

5. Vulnerability / Threat Details

Field	Assessment
Topic	CVE-2026-49869 Kestra OSS OS Command Injection Daily Priority Update 2026-09-07
Operational concern	Kestra OSS workflow-orchestration deployments, especially unauthenticated or weakly segmented instances exposed to internal users, CI/CD paths, or the internet.
Exploitation / activity status	Prioritized because current public sources indicate active exploitation, campaign activity, or material defender relevance.
Confidence	Medium-High for source-backed facts; medium for environment-specific likelihood.

6. Exposure and Attack Scenarios

Scenario	Preconditions	Defensive Review
Initial access through exposed service or social-engineering path	Affected service, identity tenant, endpoint, or supplier pathway is reachable by an attacker.	Inventory exposure, confirm patch/control status, and inspect recent logs.
Post-compromise execution and persistence	Attacker gains code execution, credentials, or remote-control foothold.	Review EDR, identity, network, and privileged activity telemetry.
Third-party or shared-platform blast radius	Supplier, SaaS, or managed-service access bridges into protected environments.	Validate vendor least privilege, segmentation, and emergency disable paths.

7. Detection Engineering

7.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
Suspicious administrative or scripting activity linked to this topic	EDR process creation	Detect exploitation follow-on commands and living-off-the-land execution.
Rare external egress or direct-IP communication	Network / proxy / EDR	Surface C2, payload retrieval, or exfiltration attempts.
Risky identity events after exposure window	IdP / Entra / VPN	Catch credential theft, MFA reset abuse, or lateral movement.

7.2. Sigma / Detection Content

<pre> title: CVE-2026-49869 Kestra OSS OS Command Injection Daily Priority Update 2026-09-07 - Defensive Activity Heuristic id: lbc-vti-2026-1153-heuristic status: experimental description: Detects suspicious process activity requiring triage in the context of CVE-2026-49869 Kestra OSS OS Command Injection Daily Priority Update 2026-09-07. logsource: product: windows category: process_creation detection: selection_terms: </pre>

CommandLine contains: - "powershell" - "curl" - "wget" - "certutil" - "whoami" - "net user" condition: selection_terms falsepositives: - Administration, vulnerability scanning, or approved testing. level: medium

8. Threat Hunting

8.1. Hunt Hypothesis

If this topic is relevant to the environment, telemetry should show suspicious exposure, execution, identity, or egress events clustered around affected assets, users, or third-party access paths.

<pre>let lookback = 14d; let terms = dynamic(["CVE-2026-49869", "CVE-2026-49869", "powershell", "curl", "wget", "certutil"]); DeviceProcessEvents where Timestamp > ago(lookback) where ProcessCommandLine has_any (terms) summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Cmds=makeset(ProcessCommandLine, 10) by DeviceName, InitiatingProcessAccountName, FileName order by LastSeen desc</pre>
<pre>DeviceNetworkEvents where Timestamp > ago(14d) where RemoteUrl has_any ("CVE-2026-49869", "download", "api") or RemotePort in (22, 4444, 8080, 8443) project Timestamp, DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl, RemotePort, InitiatingProcessCommandLine</pre>

9. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Relevant where internet-facing vulnerable services are exposed.
T1059	Command and Scripting Interpreter	Common follow-on execution after exploitation or social engineering.
T1071	Application Layer Protocol	Common C2 and payload retrieval behavior.
T1078	Valid Accounts	Relevant where identity abuse or third-party access is part of the exposure path.

10. Recommended Actions

Priority	Owner	Action
Critical	Vulnerability / Platform	Confirm whether affected assets or analogous exposure paths exist and apply vendor mitigations.
High	SOC	Run the KQL hunts and review hits with asset criticality and identity context.
High	Identity / IAM	Review privileged sign-ins, MFA changes,

		service-account use, and third-party access.
Medium	Resilience	Validate backups, restore paths, communication trees, and supplier escalation contacts.

11. References

- [1] CISA KEV alert: <https://www.cisa.gov/news-events/alerts/2026/09/02/cisa-adds-seven-known-exploited-vulnerabilities-catalog>
- [2] NVD: <https://nvd.nist.gov/vuln/detail/CVE-2026-49869>
- [3] SecurityArsenal: <https://securityarsenal.com/blog/cve-2026-49869-kestra-oss-unauthenticated-os-command-injection-actively-exploited-detection-hunting-and-remediation-guide>
- [4] CVEfeed: <https://cvefeed.io/vuln/detail/CVE-2026-49869>